

Chapitre 7

La cyber-résilience — panorama des pratiques — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — La cyber-résilience selon le FSB, gouvernance et positionnement du RSSI

- (a) Les cinq verbes de la définition FSB se répartissent selon un cycle temporel complet : « anticiper » et « s'adapter » précèdent la matérialisation d'un incident (préparation en amont), « résister » et « contenir » interviennent pendant l'incident (limitation de sa propagation et de son impact), et « se rétablir » intervient en aval (retour à la normale). Ces cinq verbes décrivent ainsi un cycle complet plutôt qu'une capacité isolée car une organisation qui excellerait sur un seul de ces verbes — par exemple une excellente capacité de rétablissement mais aucune anticipation — resterait vulnérable : la résilience, telle que définie, exige la maîtrise simultanée de l'ensemble du cycle, de l'avant-incident à l'après-incident. Le risque cyber constitue un sous-ensemble du risque informatique, et non son équivalent, car il se limite aux « vulnérabilités et menaces spécifiques » d'origine malveillante ou adverse (attaques, intrusions, rançongiciels), alors que le risque informatique au sens large couvre également des défaillances non malveillantes du système d'information — pannes matérielles, erreurs de configuration, obsolescence technologique — qui n'impliquent aucun adversaire actif. Le rapport exclut explicitement ce périmètre plus large de son analyse car son objet est précisément la dimension *adverse* du risque informatique, où la dynamique d'attaque-défense entre l'institution et des acteurs malveillants adaptatifs appelle des dispositifs de gouvernance et de test (tests d'intrusion, partage de renseignement sur la menace) sans objet pour une simple panne technique.
- (b) Pour l'automatisation : chaque processus automatisé introduit un point d'accès numérique supplémentaire (interface, API, système de contrôle) qui, à la différence d'un processus manuel, peut être sondé et exploité à distance par un adversaire sans présence physique. Pour le recours aux prestataires tiers : chaque prestataire constitue un point d'entrée potentiel vers les systèmes de l'institution, soit parce que ses propres systèmes sont directement connectés à ceux de l'institution, soit parce qu'il détient des données ou des accès qui, une fois compromis chez lui, exposent l'institution elle-même. Pour le cloud : la mutualisation d'infrastructures partagées entre de nombreux clients d'un même fournisseur cloud signifie qu'une vulnérabilité affectant ce fournisseur peut, en principe, affecter simultanément toutes les institutions qui en dépendent, bien au-delà du périmètre d'une seule d'entre elles. Ce même constat implique nécessairement un périmètre de supervision « partagé » car aucun de ces trois facteurs ne place l'intégralité du risque sous le contrôle direct de l'institution régulée : celle-ci ne peut ni auditer unilatéralement l'intégralité des systèmes d'un fournisseur cloud mondial, ni imposer seule ses standards de sécurité à l'ensemble de ses prestataires tiers, de sorte que la supervision effective du risque cyber de l'institution exige, par construction, une coopération avec ces mêmes tiers et fournisseurs.
- (c) La norme prudentielle australienne CPS 234 « impose une gouvernance claire des rôles de sécurité de l'information et une notification obligatoire des incidents matériels à l'APRA » : elle illustre la première approche, celle où « l'autorité impose des exigences sectorielles directement », puisque CPS 234 fixe elle-même des obligations précises (gouvernance des rôles, notification) plutôt que de laisser l'établissement définir sa propre stratégie. Les circulaires allemandes MaRisk et BAIT « détaillent la stratégie et la gouvernance informatiques, la gestion des risques d'information, la gestion des accès et l'externalisation » : elles relèvent également d'exigences sectorielles directement imposées par l'autorité, dans le détail des domaines couverts (gouvernance, risques d'information, accès, externalisation), illustrant elles aussi la première approche mais avec un périmètre plus large que CPS 234. La proposition des régulateurs américains (Réserve fédérale, OCC, FDIC) « dédiée aux grandes institutions financières, couvrant la gouvernance du risque cyber, la gestion des dépendances internes et externes, et la réponse aux incidents », relève elle aussi d'exigences sectorielles imposées directement — les trois cas illustrant en réalité tous la première des trois approches réglementaires, celle qui impose des exigences directes, plutôt que la deuxième (stratégie propre évaluée par le superviseur) ou la troisième (simple vérification de l'existence d'une stratégie informatique), ce qui traduit la volonté commune de ces trois juridictions de codifier des exigences cyber précises plutôt que de s'en remettre à la seule initiative des établissements.

- (d) La contradiction de priorités entre CRO et RSSI tient à ce que « le CRO privilégie la conformité » — une logique de respect de règles et de limites déjà fixées, orientée vers la maîtrise et la réduction du risque — alors que « le RSSI cherche à concilier innovation technologique et sécurité », une logique qui doit au contraire permettre l'adoption de nouvelles technologies (cloud, automatisation) tout en maîtrisant les risques qu'elles introduisent : placé sous l'autorité directe du CRO, le RSSI risque de voir ses arbitrages systématiquement tranchés en faveur de la prudence conforme plutôt que de l'innovation sécurisée, un biais structurel plutôt qu'un simple désaccord ponctuel. Un rattachement direct à la direction générale ou au conseil répond à cette contradiction en plaçant le RSSI à un niveau hiérarchique où ni la logique de conformité du CRO ni celle, potentiellement concurrente, du CIO (davantage focalisé sur la performance et la disponibilité des systèmes) ne peuvent structurellement dominer l'arbitrage cyber : ce n'est donc pas un simple changement de ligne sur l'organigramme, mais un changement du rapport de force entre logiques concurrentes au sein de l'institution. La culture de sensibilisation — formation à chaque étape du parcours salarié, programmes dédiés au conseil d'administration lui-même — est un levier complémentaire plutôt qu'un substitut au repositionnement du RSSI car elle agit sur une dimension différente du problème : le repositionnement hiérarchique du RSSI change qui arbitre les priorités cyber au sommet de l'organisation, tandis que la culture de sensibilisation change le comportement quotidien de l'ensemble des collaborateurs et, par les programmes dédiés au conseil, la capacité même du conseil à superviser la stratégie que le RSSI lui soumet — sans cette seconde dimension, un RSSI bien positionné hiérarchiquement resterait sans effet sur des comportements individuels non sensibilisés, et un conseil non formé ne pourrait pas exercer une supervision éclairée de la stratégie qu'il est censé approuver.

Corrigé de l'exercice 2 — Superviser, tester et mesurer la cyber-résilience : TIBER-EU, Resilient Shield et

- (a) Les quatre types de preuves sont : les preuves documentaires, les inspections physiques, les rapports d'incidents et les enquêtes. La cartographie et la classification des services critiques doivent précéder tout dispositif de test car elles seules permettent de hiérarchiser l'effort de supervision et de test en fonction de la criticité réelle de chaque service : tester indistinctement l'ensemble du système d'information, sans hiérarchisation préalable, disperserait des ressources de test nécessairement limitées sur des systèmes de criticité très inégale, et ferait courir le risque de sous-tester les services véritablement critiques tout en sur-testant des systèmes secondaires — la cartographie est ce qui transforme un programme de test générique en un dispositif d'assurance « robuste », proportionné aux enjeux réels de continuité et de sécurité de l'institution.
- (b) L'abandon d'un format pass/fail sert spécifiquement l'objectif de « progresser en maturité cyber » car un résultat binaire ne fait que classer l'institution d'un côté ou de l'autre d'un seuil de conformité, sans indiquer ni la nature, ni la gravité relative, ni les priorités de correction des faiblesses identifiées — une information insuffisante pour orienter un plan de progression continue. Une « évaluation des forces et des faiblesses » fournit au contraire une cartographie différenciée du niveau de maturité par domaine (détection, réponse, gouvernance...), permettant à l'institution de prioriser ses investissements de sécurité là où ses faiblesses sont les plus significatives, plutôt que de simplement chercher à franchir un seuil de réussite minimal. Le caractère « ciblé et réaliste » des tests TIBER-EU est parfaitement compatible avec cette absence de notation pass/fail — les deux caractéristiques répondent en réalité à la même logique : un test ciblé et réaliste, calibré sur le renseignement de la menace propre à l'institution testée, produit par construction un diagnostic différencié et spécifique à son profil de risque, qu'un format binaire de conformité générique ne pourrait pas restituer fidèlement.
- (c) L'exercice Resilient Shield a délibérément choisi de ne pas tester les vulnérabilités techniques internes d'une institution donnée ni la résilience opérationnelle de ses propres systèmes financiers, ce qui le distingue fondamentalement de TIBER-EU, dont l'objet est précisément d'évaluer, par un test d'intrusion réaliste, les défenses techniques et organisationnelles d'une institution testée en particulier. Un exercice de coordination inter-gouvernementale comme Resilient Shield cherche à révéler une vulnérabilité d'un ordre différent : celle des « processus

de partage d'information et de réponse aux incidents entre gouvernements et secteur financier » eux-mêmes — c'est-à-dire la capacité collective de plusieurs autorités et acteurs privés à communiquer, se coordonner et agir de concert face à une crise cyber systémique, une compétence de gouvernance collective qui ne peut être testée par l'audit technique d'une seule institution, aussi rigoureux soit-il, mais seulement par la mise en situation conjointe des mécanismes de communication entre les parties prenantes concernées.

- (d) Le patch ageing constitue un indicateur prospectif, et non purement rétrospectif, car ce qu'il mesure — le délai entre la disponibilité d'un correctif et son déploiement — n'est pas la survenue passée d'un incident, mais une *fenêtre d'exposition future* encore ouverte : tant que le correctif n'est pas déployé, la vulnérabilité reste activement exploitable, de sorte que l'indicateur signale un risque non encore matérialisé mais dont la probabilité de matérialisation croît avec le temps écoulé, à la différence d'un indicateur rétrospectif qui ne ferait que compter des incidents déjà survenus. L'hypothèse d'un « environnement stable », nécessaire à la pertinence des indicateurs rétrospectifs (le passé récent reste représentatif du futur proche), est précisément ce que des adversaires « qui adaptent continuellement leurs tactiques » rendent structurellement caduque : un historique d'incidents passés ne renseigne que sur des vecteurs d'attaque déjà connus et déjà corrigés, alors qu'un adversaire adaptatif se redirige en permanence vers les vulnérabilités les plus récentes et les moins protégées — exactement celles que seul un indicateur prospectif comme le patch ageing permet de surveiller avant qu'elles ne soient exploitées et ne deviennent, à leur tour, un simple point de plus dans les statistiques rétrospectives.

Corrigé de l'exercice 3 — Le partage d'information et la gouvernance des tiers

- (a) Les cinq catégories de flux d'information sont : entre banques, des banques vers leurs régulateurs, entre régulateurs, des régulateurs vers les banques, et avec les agences de sécurité nationales. Le caractère « informel et bilatéral » freine spécifiquement la diffusion du partage entre régulateurs car un accord bilatéral, par construction, ne lie que les deux parties signataires et ne se généralise pas automatiquement à l'ensemble des régulateurs d'un système financier mondialisé — chaque nouvelle relation bilatérale exige une négociation et une construction de confiance propres, ce qui limite mécaniquement le nombre total d'accords observés à un instant donné, à la différence d'une plateforme multilatérale comme le FS-ISAC où l'adhésion d'un nouveau membre ne requiert pas de renégocier l'ensemble du dispositif. Ce même caractère bilatéral n'empêche pas l'accord Hong Kong–Singapour de fonctionner efficacement *entre ces deux parties précises* : le constat du cours porte sur la faible diffusion du partage entre régulateurs *à l'échelle globale* (peu d'accords bilatéraux couvrant l'ensemble des paires de juridictions), non sur l'inefficacité de chaque accord bilatéral pris isolément, qui peut au contraire, comme le montre cet exemple précis, se révéler pleinement opérationnel entre les deux parties qui l'ont négocié.
- (b) Sans anonymisation, une banque membre du FS-ISAC qui signalerait avoir subi une vulnérabilité ou une attaque risquerait d'être identifiée nommément par ses concurrents, ses clients ou le marché, avec un coût réputationnel et concurrentiel direct — une contrepartie négative certaine, immédiate et propre au déclarant, face à un bénéfice collectif diffus (la sécurité globale du secteur) dont elle ne capterait qu'une fraction. Ce déséquilibre inciterait rationnellement chaque banque à retarder ou à minimiser ses signalements, voire à s'abstenir totalement d'y participer, un comportement de passager clandestin qui viderait le dispositif de partage de son utilité collective ; l'anonymisation supprime précisément ce coût individuel de la déclaration (aucune banque n'étant identifiable comme la source d'une alerte), alignant ainsi l'intérêt individuel de chaque membre sur l'objectif collectif de diffusion rapide de l'information de menace.
- (c) Les cinq principes de l'accord Hong Kong–Singapour sont : la rapidité (partage sous 24 heures en cas de risque de propagation transfrontalière), le caractère volontaire, la confidentialité, l'efficacité (partage non limité aux seules institutions présentes dans les deux juridictions), et l'usage d'un protocole de classification standardisé (Traffic Light Protocol) et d'une taxonomie commune (STIX). La standardisation via TLP et STIX sert spécifiquement le principe d'efficacité car elle rend l'information partagée directement compréhensible et exploitable par des institutions et des systèmes tiers, au-delà des seules parties fondatrices de l'accord : sans

un langage commun de classification (TLP, qui indique le niveau de diffusion autorisé d'une information) et de structuration (STIX, qui formalise la description technique d'une menace), chaque destinataire supplémentaire hors des deux juridictions fondatrices devrait retraduire ou réinterpréter l'information reçue, ce qui limiterait de fait sa diffusion effective à un cercle restreint — exactement ce que le principe d'efficacité cherche à éviter. Le mécanisme de notification obligatoire aux CSIRT sous la directive NIS correspond à la catégorie « des banques vers leurs régulateurs » (ou vers une agence de sécurité assimilée à un régulateur au sens large) identifiée au (a) ; son caractère *obligatoire* — imposé par la directive à tout « opérateur de service essentiel » sous peine de manquement réglementaire — le distingue nettement du caractère « volontaire » de l'accord Hong Kong–Singapour, qui repose sur l'adhésion consentie des deux autorités signataires plutôt que sur une contrainte légale s'imposant aux institutions elles-mêmes.

- (d) Classer un fournisseur d'« alimentation électrique » dans le même périmètre de gouvernance des tiers que les prestataires cloud change concrètement la gestion de cette relation car cela impose d'y appliquer les mêmes exigences que pour tout autre tiers cyber-critique : analyse préalable des risques (de continuité d'activité, de dépendance, de concentration), clauses contractuelles de continuité et, potentiellement, un droit d'inspection — des dispositifs qu'une institution n'aurait spontanément appliqués qu'à ses prestataires informatiques, alors qu'une coupure d'alimentation électrique peut interrompre ses services opérationnels importants tout aussi sûrement qu'une cyberattaque, justifiant un traitement de gouvernance équivalent malgré la nature non numérique du service. Le format de « sommet réglementaire » organisé par certains fournisseurs de cloud cherche à résoudre « la difficulté, pour un régulateur national isolé, d'exercer une supervision effective sur un fournisseur mondial » : un régulateur national ne dispose ni du pouvoir juridictionnel ni des ressources pour auditer seul un fournisseur cloud opérant dans des dizaines de juridictions et servant des milliers de clients à travers le monde, tout comme un superviseur bancaire national isolé ne pourrait exercer seul une supervision complète d'une banque véritablement internationale — d'où le recours, par analogie directe avec le « collège de superviseurs » bancaire, à une coordination collective de plusieurs autorités pour mutualiser l'information et le pouvoir de supervision face à un fournisseur dont l'échelle dépasse structurellement le ressort de toute autorité nationale prise isolément.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — La cyber-résilience à la lumière des quatre chapitres précédents

- (a) L'exigence de ce chapitre d'une stratégie cyber « approuvée par le conseil d'administration » est une application directe, au cas du risque cyber, du rôle général confié par le chapitre 6 au comité des risques du conseil sur « l'ensemble des risques de l'organisation » : ce comité, qui supervise indistinctement le risque de crédit, de marché, de liquidité et opérationnel selon le chapitre 6, exerce sur le risque cyber la même fonction de supervision et d'approbation stratégique au sommet que sur toute autre catégorie de risque financier ou non financier — la stratégie cyber approuvée par le conseil n'est donc pas un dispositif de gouvernance *propre* au risque cyber, mais l'instanciation, pour ce risque particulier, du mécanisme déjà généralisé par le chapitre 6. Le débat de ce chapitre sur le rattachement « sous-optimal » du RSSI au CRO complique la lecture simple d'un organigramme net du chapitre 6, où chaque risque semble disposer de « son » responsable dédié de deuxième ligne juxtaposé aux autres (crédit, marché, liquidité, RSSI) : ce chapitre révèle que ces fonctions de deuxième ligne ne sont pas de simples silos parallèles sans interaction, mais peuvent entretenir des relations hiérarchiques directes (le RSSI *sous* le CRO) porteuses de tensions de priorités documentées — montrant qu'une deuxième ligne « organisée par type de risque » au sens du chapitre 6 peut receler, en pratique, une architecture interne plus complexe et plus disputée que la simple énumération d'une liste de responsables ne le suggère.
- (b) Le patch ageing de ce chapitre est un cas concret et chiffrable de ce que le chapitre 5 ne fait que nommer abstraitement sous le terme de « veille prospective (horizon scanning) » appliquée au risque cyber : le chapitre 5 définit cette composante du reporting comme

« tournée vers l’avenir », sans en donner d’exemple opérationnel précis pour le risque cyber, tandis que ce chapitre fournit exactement cet exemple — un indicateur mesurable, comparable dans le temps et entre institutions, qui matérialise concrètement ce que le chapitre 5 ne fait qu’esquisser conceptuellement. Le retard que ce chapitre constate dans le développement de tels indicateurs prospectifs (« encore peu harmonisés d’une juridiction à l’autre ») illustre, pour le domaine cyber spécifiquement, le même manque que le chapitre 5 identifie de façon générale pour l’ensemble du risque opérationnel lorsqu’il observe que « la plupart des juridictions se concentrent encore sur des indicateurs rétrospectifs » : le chapitre 5 pose le problème au niveau du principe général de reporting, ce chapitre en documente empiriquement une instance particulière et non résolue. Selon la logique du « gâteau du reporting » du chapitre 5, une évaluation TIBER-EU révélant une faiblesse structurelle de la gouvernance cyber devrait remonter au conseil d’administration *sous forme de conclusion synthétique uniquement*, et non dans le détail : le chapitre 5 précise explicitement que seul un événement qui « révèle une faiblesse structurelle de contrôle affectant l’appétit pour le risque de l’organisation » justifie une remontée au conseil, et que, dans ce cas, « seule sa conclusion [...] remonte au conseil d’administration » — le détail technique complet de l’évaluation TIBER-EU (les vecteurs d’attaque testés, les vulnérabilités précises identifiées) relevant, selon ce même modèle, des strates opérationnelle et de management, non de la strate stratégique réservée au conseil.

- (c) Ce dispositif contractuel de ce chapitre — cadre d’externalisation approuvé par le conseil, clauses garantissant un droit d’inspection et d’audit — est une déclinaison précise, au cas du risque cyber logé chez un tiers, du principe général du chapitre 4 selon lequel l’externalisation « ne transfère jamais la responsabilité vis-à-vis du client final » : puisque l’institution demeure responsable même lorsque l’exécution technique est déléguée à un tiers ou à un fournisseur cloud, elle doit nécessairement conserver un moyen de s’assurer que ce tiers maîtrise effectivement le risque cyber qu’il porte pour son compte — ce moyen étant précisément le droit d’audit et d’inspection que ce chapitre exige contractuellement. Sans transfert de responsabilité ni droit d’audit, il ne resterait à l’institution, pour maîtriser ce risque logé chez un tiers, que le choix initial du prestataire et la rupture éventuelle du contrat après coup : deux leviers bien plus grossiers et bien plus tardifs qu’un contrôle contractuel continu, ce qui explique pourquoi le cours insiste sur ce droit d’audit comme composante indispensable de la gouvernance des tiers. Le test d’intrusion TIBER-EU de ce chapitre est bien une instance du niveau de rigueur le plus élevé défini au chapitre 4 — la « reperformance [...] la forme de test la plus exigeante », illustrée par « le client mystère ou l’insertion de transactions fictives » — car TIBER-EU, tout comme ces deux exemples, ne se contente pas d’examiner des preuves documentaires ou d’observer un contrôle en fonctionnement : il reproduit activement, dans des conditions réalistes, le comportement même d’un adversaire (comme le client mystère reproduit celui d’un client) pour vérifier empiriquement, plutôt que de le présumer, que l’ensemble du dispositif de défense résiste effectivement à l’épreuve — la seule différence étant que TIBER-EU applique cette logique de reperformance non à un contrôle isolé, mais à l’ensemble intégré du dispositif de cyber-résilience d’une institution.
- (d) Sans la cartographie des dépendances qu’exige la troisième étape de la méthode du chapitre 3 (« cartographier les ressources et dépendances nécessaires à [la] délivrance » des IBS), le « préalable » que ce chapitre exige avant tout test d’intrusion ou toute mesure de résilience cyber n’aurait tout simplement aucun objet concret sur lequel porter : la cartographie et la classification des services d’affaires critiques que ce chapitre exige *est*, pour le domaine cyber, exactement cette troisième étape du chapitre 3 — sans elle, un test TIBER-EU ne saurait ni quels systèmes cibler en priorité, ni quelles dépendances tierces (fournisseurs, infrastructures) inclure dans son périmètre, ni quelle criticité attribuer à chaque vulnérabilité découverte. L’exemple de SPOF du chapitre 3 — une « dépendance [...] à un prestataire cloud unique », à « éliminer par la redondance lorsque c’est possible » — annonce précisément le sujet de la section de ce chapitre consacrée aux interconnexions tierces et à la gouvernance du cloud : ce chapitre ne fait que déployer, pour ce cas particulier déjà identifié comme structurel par le chapitre 3, le dispositif de gouvernance complet (cadre d’externalisation approuvé par le conseil, droit d’audit, sommets réglementaires organisés avec les fournisseurs mondiaux de cloud) que le chapitre 3 se contentait

de recommander en un mot — « la redondance » — sans détailler comment une institution négocie, contractualise et fait superviser cette dépendance résiduelle lorsque la redondance elle-même n'est pas immédiatement réalisable.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Le vieillissement des correctifs (patch ageing) : un indicateur prospectif chiffré

On a quatre systèmes avec (n , âge moyen en jours, coût/jour-vuln.) : Cœur bancaire (8, 12, 3 000), Canaux clients (15, 28, 1 200), Back office (5, 45, 600), Prestataire cloud tiers (6, 60, 2 000).

- (a) Cœur bancaire : jours-vulnérabilité = $8 \times 12 = 96$, coût d'exposition = $96 \times 3\,000 = 288\,000$ €. Canaux clients : jours-vulnérabilité = $15 \times 28 = 420$, coût = $420 \times 1\,200 = 504\,000$ €. Back office : jours-vulnérabilité = $5 \times 45 = 225$, coût = $225 \times 600 = 135\,000$ €. Prestataire cloud tiers : jours-vulnérabilité = $6 \times 60 = 360$, coût = $360 \times 2\,000 = 720\,000$ €. Le coût d'exposition total du portefeuille est $288\,000 + 504\,000 + 135\,000 + 720\,000 = 1\,647\,000$ €.
- (b) Les contributions au coût total de 1 647 000 € sont : Cœur bancaire = $288\,000/1\,647\,000 = 17,4863\%$; Canaux clients = $504\,000/1\,647\,000 = 30,6011\%$; Back office = $135\,000/1\,647\,000 = 8,1967\%$; Prestataire cloud tiers = $720\,000/1\,647\,000 = 43,7158\%$. Le prestataire cloud tiers domine effectivement cette exposition chiffrée, avec près de 44 % du coût total à lui seul, et il s'agit bien également du système dont l'âge moyen de retard est le plus élevé (60 jours) : classement par âge moyen et classement par coût d'exposition coïncident donc ici. Cette coïncidence n'a toutefois rien de mécanique — les canaux clients, avec un âge moyen bien inférieur (28 jours contre 60), pèsent malgré tout 30,60 % du coût total grâce à un volume de correctifs en retard ($n = 15$) plus de deux fois supérieur à celui du cloud tiers ($n = 6$) : c'est la combinaison du volume, de l'âge et du coût unitaire, non l'âge seul, qui détermine le classement par coût d'exposition.
- (c) L'âge moyen pondéré du portefeuille, pondéré par le nombre de correctifs de chaque système, est $\frac{8 \times 12 + 15 \times 28 + 5 \times 45 + 6 \times 60}{8 + 15 + 5 + 6} = \frac{96 + 420 + 225 + 360}{34} = \frac{1\,101}{34} = 32,3824$ jours. Ce chiffre pondéré **dépasse** le seuil d'alerte de 30 jours fixé par la banque, de 2,3824 jours. Pris individuellement, deux systèmes dépassent déjà ce même seuil : le **back office** (45 jours) et le **prestataire cloud tiers** (60 jours) ; les deux autres (cœur bancaire à 12 jours, canaux clients à 28 jours) restent en deçà.
- (d) Le nouveau coût d'exposition du prestataire cloud tiers, avec un âge ramené de 60 à 20 jours pour le même $n = 6$, est $6 \times 20 \times 2\,000 = 240\,000$ € (contre 720 000 € avant investissement). La réduction de coût d'exposition est $720\,000 - 240\,000 = 480\,000$ € par an. Le bénéfice net de l'investissement est $480\,000 - 45\,000 = 435\,000$ € par an (soit un ratio bénéfice/coût de $480\,000/45\,000 = 10,6667$) : l'investissement est très largement rentable. Le nouvel âge moyen pondéré du portefeuille devient $\frac{96 + 420 + 225 + 6 \times 20}{34} = \frac{96 + 420 + 225 + 120}{34} = \frac{861}{34} = 25,3235$ jours, qui repasse bien **sous** le seuil d'alerte de 30 jours — l'investissement ciblé sur le seul système en tête de l'exposition chiffrée suffit à ramener l'indicateur agrégé du portefeuille entier en zone de conformité interne.

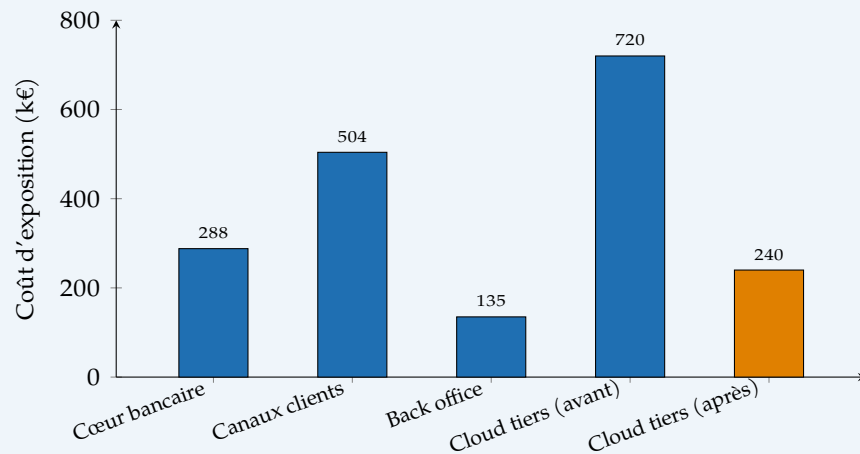


FIG. 1 : Coût d'exposition annuel par système (en k€) : les quatre systèmes actuels (bleu), et le prestataire cloud tiers après l'investissement de 45 k€/an ramenant son âge moyen de retard de 60 à 20 jours (orange) — exercice 5.

Corrigé de l'exercice 6 — La valeur du partage d'information : FS-ISAC et l'accord Hong Kong–Singapour

On a $N = 40$ banques, 39 banques restantes exposées, une probabilité journalière $p = 2\%$, et un coût moyen par banque compromise de 2 500 k€.

- Sans partage (fenêtre de 6 jours) : banques additionnellement compromises = $39 \times 0,02 \times 6 = 4,68$. Avec partage de type FS-ISAC ou accord Hong Kong–Singapour (fenêtre de 1 jour) : banques additionnellement compromises = $39 \times 0,02 \times 1 = 0,78$.
- Sans partage : total de banques touchées = $1 + 4,68 = 5,68$, pour une perte sectorielle attendue de $5,68 \times 2\,500 = 14\,200$ k€. Avec partage : total = $1 + 0,78 = 1,78$, pour une perte de $1,78 \times 2\,500 = 4\,450$ k€. La réduction de perte attendue permise par le partage d'information est $14\,200 - 4\,450 = 9\,750$ k€, soit $9\,750/14\,200 = 68,6620\%$ de réduction relative par rapport à la perte sans partage.
- Le coût total de cotisation au centre d'échange est $80 \times 40 = 3\,200$ k€ par an. Avec une fréquence annuelle de 0,5 (une attaque de ce type tous les deux ans), le bénéfice annualisé du partage d'information est $9\,750 \times 0,5 = 4\,875$ k€ par an. Le bénéfice net annuel est $4\,875 - 3\,200 = 1\,675$ k€ par an, pour un ratio bénéfice/coût de $4\,875/3\,200 = 1,5234$: le dispositif de partage d'information est donc **justifié économiquement** à l'échelle du secteur, son bénéfice annualisé dépassant de plus de 50 % son coût de fonctionnement.
- Avec un délai dégradé de 3 jours (participation partielle faute d'anonymat) : banques additionnellement compromises = $39 \times 0,02 \times 3 = 2,34$, pour une perte sectorielle attendue de $(1 + 2,34) \times 2\,500 = 3,34 \times 2\,500 = 8\,350$ k€. La réduction de perte encore obtenue par rapport à l'absence totale de partage est $14\,200 - 8\,350 = 5\,850$ k€. Le « coût de la perte du principe d'anonymat » est l'écart entre la réduction de perte obtenue avec anonymisation intégrale (9 750 k€ au (b)) et celle obtenue dans ce scénario dégradé (5 850 k€), soit $9\,750 - 5\,850 = 3\,900$ k€ par événement, ou $3\,900 \times 0,5 = 1\,950$ k€ annualisés (même fréquence qu'au (c)). Ce seul renoncement au principe d'anonymat ferait perdre $3\,900/9\,750 = 40,0000\%$ du bénéfice total du partage d'information — une illustration chiffrée directe de ce que le cours affirme lorsqu'il qualifie l'anonymisation de « principe de confidentialité jugé essentiel » : sa suppression ne détruit pas la totalité de la valeur du dispositif de partage (une participation partielle reste préférable à l'absence totale de partage), mais elle en efface près de la moitié.

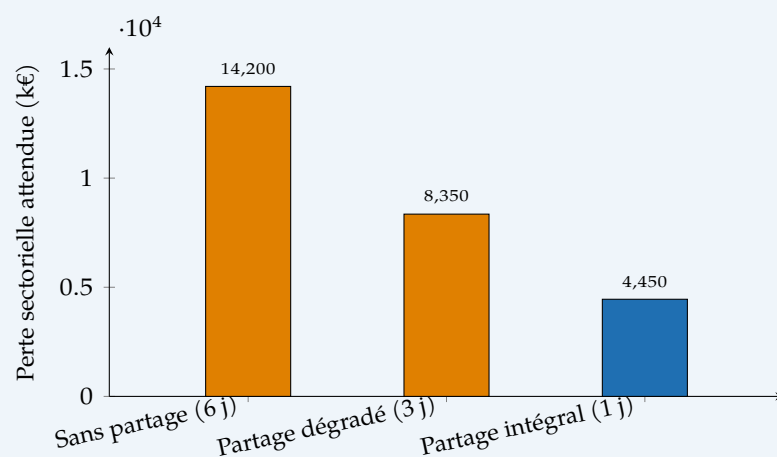


FIG. 2 : Perte sectorielle attendue selon le régime de partage d'information : sans partage (6 jours), partage dégradé sans anonymat garanti (3 jours), et partage intégral de type FS-ISAC / accord Hong Kong–Singapour (1 jour) — exercice 6.